

RISK ASSESSMENT

Risk assessment is the process of identifying, analyzing, and evaluating potential risks that could negatively affect an organization, system, project, or asset.

In cybersecurity, think of it as answering three main questions:

1. What can go wrong?

Identify possible threats and vulnerabilities.

- Threats: malware, phishing, insider attacks, ransomware, hardware failure, natural disasters.
- Vulnerabilities: weak passwords, outdated software, open ports, misconfigured firewalls.

2. How likely is it to happen?

Estimate the probability of a risk occurring.

Example:

- A public-facing web app with outdated libraries has a **high likelihood** of attack.
- A disconnected offline backup server has a **low likelihood** of remote compromise.

3. What would be the impact if it happens?

Measure consequences such as:

- Financial loss
- Data breach
- Reputation damage
- Legal/compliance penalties
- Operational downtime

A simple formula often used is:

Risk = Likelihood × Impact

Example:

- Vulnerability: Unpatched server

- Threat: Exploitation by attacker
- Likelihood: High
- Impact: High (sensitive data exposed)
- Risk Level: Critical

You can visualize this with a risk matrix:

Likelihood	Low Impact	Medium Impact	High Impact
Low	Low Risk	Low Risk	Medium Risk
Medium	Low Risk	Medium Risk	High Risk
High	Medium Risk	High Risk	Critical Risk

Steps in Risk Assessment

1. Asset Identification

Identify what needs protection:

- Servers
- Databases
- Endpoints
- Applications
- Customer data

2. Threat Identification

Determine possible threats.

3. Vulnerability Assessment

Find weaknesses in the system.

4. Risk Analysis

Analyze likelihood and impact.

5. Risk Evaluation/Prioritization

Rank risks from highest to lowest.

6. Risk Treatment/Mitigation

Decide how to handle risks:

- Avoid: stop risky activity
- Mitigate: apply controls (patching, MFA, encryption)
- Transfer: insurance or outsourcing
- Accept: tolerate low-level risk

Types of Risk Assessment

- **Qualitative Risk Assessment**
Uses labels like Low/Medium/High.
- **Quantitative Risk Assessment**
Uses numbers, probabilities, and financial values.
Example: Annual Loss Expectancy (ALE).
- **Hybrid Assessment**
Mix of both.

Example in Cybersecurity

A company stores customer payment data.

- Asset: Payment database
- Threat: SQL Injection attack
- Vulnerability: Unsanitized input fields
- Likelihood: Medium
- Impact: High
- Risk Score: High

Mitigation:

- Input validation
- Web Application Firewall
- Secure coding practices
- Regular penetration testing

Why risk assessment matters:

- Helps prioritize security spending
- Reduces incidents
- Supports compliance (like ISO 27001, NIST Cybersecurity Framework, PCI DSS)
- Improves decision-making

In short: **Risk assessment helps organizations decide what to protect first instead of trying to secure everything equally.**

Risk Treatment Strategies

After assessing risks, choose a response.

1. Avoid

Eliminate the activity causing risk.

Example:

- Disable unsupported legacy service

2. Mitigate

Reduce risk with controls.

Example:

- Patch systems
- Enable MFA
- Network segmentation

3. Transfer

Shift risk to third party.

Example:

- Cyber insurance
- Managed security services

4. Accept

Accept low risk when mitigation cost is too high.

Example:

- Low-severity vulnerability on isolated internal system

Risk Assessment Lifecycle

Risk assessment is continuous:

1. Identify assets
2. Detect threats
3. Find vulnerabilities
4. Analyze likelihood
5. Analyze impact
6. Prioritize risks
7. Remediate
8. Reassess